

# 제138회 정보관리기술사 해설집

2026.02.07

## 국가기술자격 기술사 시험문제

기술사 제 138 회

제 3 교시 (시험시간: 100 분)

|    |      |      |         |          |  |        |  |
|----|------|------|---------|----------|--|--------|--|
| 분야 | 정보통신 | 자격종목 | 정보관리기술사 | 수검<br>번호 |  | 성<br>명 |  |
|----|------|------|---------|----------|--|--------|--|

※ 다음 문제 중 4 문제를 선택하여 설명하시오. (각 10 점)

1. 최근 생성형 인공지능 서비스 확산에 따라 이용자 권리 보호를 위한 목적으로 생성형 인공지능 서비스 이용자 보호 가이드라인(2025. 2. 28.)을 제정하였다. 다음 내용을 설명하시오.

가. 가이드라인 제정된 배경 및 필요성

나. 가이드라인에서 제시하는 이용자 보호의 실행방식을 4 가지 제시하고, 각 방식이 생성형 AI 서비스에서 중요한 이유

2. A 사는 신규 정보시스템 개발 프로젝트에 로우코드(Low Code) 플랫폼을 적용하고자 한다. 다음 내용을 설명하시오.

가. 로우코드(Low Code)의 주요 특징

나. 노코드(No Code)와 로우코드(Low Code) 비교

다. 로우코드(Low Code) 적용 시 한계점

3. 분산 데이터베이스 시스템 구축을 위한 데이터베이스 분할에 대하여 다음 내용을 설명하시오.

가. 데이터베이스 분할 단위

나. 수평분할과 수직분할

4. 가용성 보장에 대하여 다음 내용을 설명하시오.

가. FTS(Fault Tolerant System) 구현 방법

나. HA(High Availability) 구현 방법

다. FTS 와 HA 비교 설명

5. IT 인프라 확장에 따른 사이버 위협에 대하여 다음 내용을 설명하시오.

가. 공격 표면(Attack Surface)과 공격 벡터(Attack Vector)

나. 측면 이동(Lateral Movement)의 단계별 메커니즘과 주요 기법

6. 최근 보안과 관련된 사고 및 이슈의 빈번한 발생으로 정보보호를 위한 관리체계에 대한 중요성이 부각되고 있다. 다음 내용을 설명하시오.

가. 정보보호 관리체계(ISMS)의 인증 영역과 법적 근거

나. 정보보호 관리체계(ISMS)의 관리 과정

다. ISMS-P 간편인증 제도

라. ISMS-P 제도의 강화 방안

|      |                                                                                                                                                                                                                      |     |           |
|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----------|
| 01   | 생성형 인공지능 서비스 이용자 보호                                                                                                                                                                                                  |     |           |
| 문제   | <p>최근 생성형 인공지능 서비스 확산에 따라 이용자 권리 보호를 위한 목적으로 생성형 인공지능 서비스 이용자 보호 가이드라인(2025. 2. 28.)을 제정하였다. 다음 내용을 설명하시오.</p> <p>가. 가이드라인 제정된 배경 및 필요성</p> <p>나. 가이드라인에서 제시하는 이용자 보호의 실행방식을 4가지 제시하고, 각 방식이 생성형 AI 서비스에서 중요한 이유</p> |     |           |
| 도메인  | 인공지능                                                                                                                                                                                                                 | 난이도 | 중 (상/중/하) |
| 키워드  | 인격권 보호, 투명성 확보 및 알림, 다양성 존중 및 차별 방지, 입력 데이터 보호 및 선택권 보장                                                                                                                                                              |     |           |
| 출제배경 | 생성형 인공지능 서비스 이용자 보호 가이드라인 발표에 따른 출제                                                                                                                                                                                  |     |           |
| 참고문헌 | 생성형 인공지능 서비스 이용자 보호 가이드라인(2025.02, 방송통신위원회)                                                                                                                                                                          |     |           |
| 출제자  | 강남평일야간반 전일 기술사(제 114회 정보관리기술사 / nikki6@hanmail.net)                                                                                                                                                                  |     |           |

## I. 생성형 인공지능 서비스 이용자 보호 가이드라인 개요

|              |                                                                                                                                                                                                                                                            |
|--------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 생성형 인공지능 서비스 | - 생성형 인공지능을 활용하여 공공 또는 민간에게 제공되는 서비스                                                                                                                                                                                                                       |
| 가이드라인 목적     | <ul style="list-style-type: none"> <li>- 잠재적 위험의 사전 방지와 이용자 권익 보호를 위해 실천 방안을 제시</li> <li>- 안전하고 신뢰할 수 있는 생성형 인공지능 환경 조성이 목표</li> <li>- 생성형 인공지능의 올바른 사용을 통해 모든 사회구성원이 혜택을 누리도록 하는 것을 지향</li> <li>- 자율적 참여와 책임감 있는 생태계 구성을 통해 효율적인 이용자 보호 체계를 구축</li> </ul> |
| 가이드라인 적용범위   | <ul style="list-style-type: none"> <li>- 생성형 인공지능 개발사 및 서비스 제공자, 이용자</li> <li>- 생성형 인공지능 서비스 및 산출물</li> </ul>                                                                                                                                              |

- 가이드라인에서는 생성형 인공지능 서비스의 전반에 걸쳐 추구해야 할 원칙과 실행방식을 제시

## II. 가이드라인 제정된 배경 및 필요성

### 가. 가이드라인 제정 배경

| 구분     | 배경          | 세부내용                           |
|--------|-------------|--------------------------------|
| 기술 발전  | - 생성형 AI 확산 | - 콘텐츠 자동 생성, 대규모 모델, 활용 서비스 증가 |
| 활용 확대  | - 산업·업무 적용  | - 비즈니스 혁신, 업무 효율성, 생산성 향상      |
| 환경 변화  | - 이용 환경 급변  | - 빠른 확산, 이용자 이해 부족, 기술 인식 격차   |
| 부작용 발생 | - 사회적 이슈    | - 편향, 허위정보, 오·남용               |
| 제도 한계  | - 기존 체계 미흡  | - 기존 법·제도의 적용 한계               |

### 나. 가이드라인 제정 필요성

| 구분     | 필요성     | 세부내용                |
|--------|---------|---------------------|
| 이용자 보호 | - 권익 보호 | - 인격권, 프라이버시, 피해 예방 |

|        |            |                         |
|--------|------------|-------------------------|
| 위험 관리  | - 사전 통제    | - 편향 완화, 오남용 방지, 안전성 확보 |
| 신뢰 확보  | - 신뢰 기반    | 투명성, 설명 가능성, 책임성        |
| 정책 대응  | - 가이드라인 필요 | 제도 공백 보완, 공공 기준 제시      |
| 지속 가능성 | - 건전한 생태계  | 책임 있는 AI, 장기 확산 기반      |

### III. 이용자 보호의 실행방식 4가지와 각 방식이 생성형 AI서비스에서 중요한 이유

#### 가. 가이드라인에서 제시하는 이용자 보호의 실행방식을 4가지

| 구분                   | 실행 방식                                 | 핵심 내용                                                  |
|----------------------|---------------------------------------|--------------------------------------------------------|
| ① 인격권 보호             | - 명예훼손·사생활 침해 등 인격권 침해 예방·대응 체계 마련    | - 생성형 AI는 사람처럼 서술·표현하여 허위·왜곡 정보가 직접적인 인권 침해로 이어질 위험이 큼 |
| ② 투명성 확보 및 알림        | - AI 생성물 고지, 서비스 작동 원리·한계에 대한 정보 제공   | - 이용자의 과신(Automation Bias)을 방지하고 합리적 판단을 돕기 위해 필수      |
| ③ 다양성 존중 및 차별 방지     | - 편향·차별 최소화를 위한 설계·운영·관리              | - 학습 데이터 편향이 사회적 차별을 증폭시킬 수 있어 공정성 확보가 중요              |
| ④ 입력 데이터 보호 및 선택권 보장 | - 입력·생성 데이터의 수집·학습·활용에 대한 고지 및 선택권 제공 | - 입력 데이터가 곧 학습 자원이 되어 프라이버시 침해 위험이 높음                  |

#### 나. 이용자 보호의 실행방식을 4가지가 생성형 AI서비스에서 중요한 이유

| 실행방식               | 중요 이유                | 생성형 AI 서비스에서의 의미                             |
|--------------------|----------------------|----------------------------------------------|
| 인격권 보호             | - 인권 침해 위험, 허위·왜곡 생성 | - 사람과 유사한 표현 생성으로 명예훼손·사생활 침해가 직접 발생 가능      |
| 투명성 확보 및 알림        | - 과신 방지, 신뢰 통제       | - AI 결과를 사실로 오인하는 자동화 편향(Automation Bias) 예방 |
| 다양성 존중 및 차별 방지     | - 편향 증폭, 사회적 차별      | - 학습 데이터 편향이 차별·혐오 표현으로 확대될 위험               |
| 입력 데이터 보호 및 선택권 보장 | - 프라이버시 침해, 통제권      | - 입력 데이터가 학습에 활용되어 개인 정보·민감정보 유출 가능          |

- 가이드라인에서는 이용자 보호의 실행방식이 6가지로 기술되어 있음
- 문제 해결 및 피해 구제, 건전한 유통 및 오남용 방지가 가이드라인에 추가로 존재

### IV. 생성형 인공지능 서비스 이용자 보호 실행 사례

| 구분         | 실행 사례                                              | 설명                                   |
|------------|----------------------------------------------------|--------------------------------------|
| 이용자 인격권 보호 | - 혐오 표현 예방을 위해 프롬프트 입력 시 경고 문구를 제시하거나 일정 시간 입력을 차단 | - 인격권 침해를 사전에 방지하기 위한 사전 경고 및 기술적 제어 |

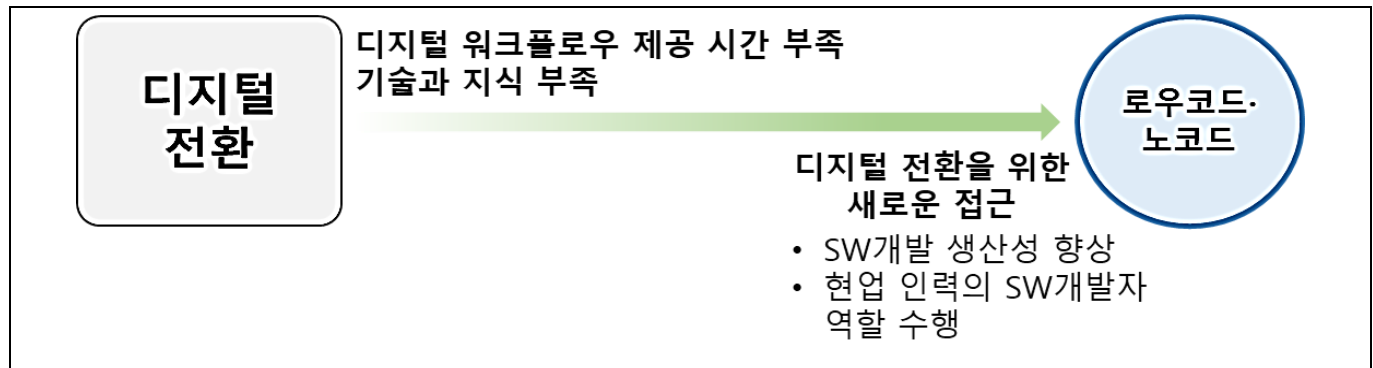
|                    |                                                |                                                 |
|--------------------|------------------------------------------------|-------------------------------------------------|
| 콘텐츠 유통의 건<br>전성 유지 | - 청소년 유해 콘텐츠에 대해 경고 문구를<br>표시하거나, 서비스 연령 제한 설정 | - 서비스 이용자 중 청소년 보호를 위한<br>기술적 조치 및 서비스 이용 조건 설정 |
|--------------------|------------------------------------------------|-------------------------------------------------|

- 가이드를 통하여 안전하고 신뢰할 수 있는 생성형 인공지능 환경 조성  
과 자율적 참여와 책임감 있는 생태계 구성을 통해 효율적인 이용자 보호 체계를 구축 가능

“끝”

|      |                                                                                                                                                                  |     |          |
|------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----------|
| 02   | 로우코드·노코드 기술                                                                                                                                                      |     |          |
| 문제   | A사는 신규 정보시스템 개발 프로젝트에 로우코드(Low Code) 플랫폼을 적용하고자 한다. 다음 내용을 설명하시오.<br>가. 로우코드(Low Code)의 주요 특징<br>나. 노코드(No Code)와 로우코드(Low Code) 비교<br>다. 로우코드(Low Code) 적용 시 한계 |     |          |
| 도메인  | 소프트웨어공학                                                                                                                                                          | 난이도 | 상(상/중/하) |
| 키워드  | SW개발생산성, SW개발인력 확대, 디지털전환도구, 시각적 IDE, UI모델링, 데이터 모델                                                                                                              |     |          |
| 출제배경 | 로우코드·노코드 개념, 특징, 고려사항 이해                                                                                                                                         |     |          |
| 참고문헌 | ITPE 서브노트                                                                                                                                                        |     |          |
| 해설자  | 강남평일야간반 전일 기술사(제 114회 정보관리기술사 / nikki6@hanmail.net)                                                                                                              |     |          |

#### I. 디지털전환 촉진을 위한 새로운 접근, 로우코드·노코드



- 현업과 IT 전담 부서 간의 협업과 소통을 돕고 디지털 전환 역량 확보를 위하여 현업에서 직접 시각화 도구, 드래그 앤 드롭 방식으로 프로토타입 제작이 가능한 로우코드·노코드 활용

#### II. 로우코드(Low Code)의 주요 특징

##### 가. 개발 방식·기술적 특징

| 구분    | 특징       | 설명                    |
|-------|----------|-----------------------|
| 개발 방식 | 시각적 개발   | - 드래그앤드롭 기반 화면·로직 설계  |
| 코딩 수준 | 최소 코딩    | - 설정·구성 중심, 코드 작성 최소화 |
| 생산성   | 빠른 개발    | - 개발·테스트·배포 기간 단축     |
| 재사용성  | 컴포넌트 재사용 | - 표준 컴포넌트·템플릿 활용      |
| 확장성   | 코드 확장 가능 | - 필요 시 커스텀 코드로 기능 보완  |

##### 나. 운영·조직·비즈니스 특징

| 구분    | 특징     | 설명                    |
|-------|--------|-----------------------|
| 참여 주체 | 시민 개발자 | - 비개발자·현업도 개발 참여 가능   |
| 표준화   | 일관된 구조 | - 공통 개발 규칙으로 품질 확보    |
| 통합성   | 연계 용이  | - API·DB·외부 시스템 연계 지원 |

|         |     |                   |
|---------|-----|-------------------|
| 운영 효율   | 자동화 | - 배포·버전·환경 관리 자동화 |
| 비즈니스 대응 | 민첩성 | - 요구사항 변화에 빠른 대응  |

- 로우코드는 빠른 개발과 확장성을 동시에 만족시키는 실용적 개발 방식

### III. 노코드(No Code)와 로우코드(Low Code) 비교

#### 가. 노코드와 로우코드의 개념 비교

| 구분    | 노코드 (No Code)      | 로우코드 (Low Code)       |
|-------|--------------------|-----------------------|
| 기본 개념 | - 코딩 없이 애플리케이션 개발  | - 최소한의 코딩으로 애플리케이션 개발 |
| 개발 목적 | - 누구나 빠르게 앱 제작     | - 개발 생산성 향상 + 확장성 확보  |
| 주요 대상 | - 비개발자, 현업(시민 개발자) | - 개발자 + 현업 협업         |
| 개발 철학 | - 설정·구성 중심         | - 시각적 개발 + 코드 보완      |
| 적용 범위 | - 단순·표준 업무         | - 중·복잡 업무, 엔터프라이즈     |

#### 가. 노코드와 로우코드의 상세 비교

| 구분       | 노코드 (No Code)         | 로우코드 (Low Code)      |
|----------|-----------------------|----------------------|
| 개발 방식    | - 완전 시각적(Drag & Drop) | - 시각적 개발 + 코드 작성     |
| 코딩 가능 여부 | - 불가                  | - 가능(필요 시)           |
| 복잡한 로직   | - 구현 제한 큼             | - 커스텀 코드로 구현 가능      |
| 확장성      | - 낮음                  | - 높음                 |
| 유연성      | - 플랫폼 기능에 종속          | - 외부 API·라이브러리 연계 가능 |
| 성능 최적화   | - 제한적                 | - 비교적 용이             |
| 유지보수     | - 플랫폼 의존적             | - 표준화로 관리 용이         |
| 대표 활용    | - 업무 자동화, 간단한 앱       | - 업무시스템, 대규모 서비스     |

- 노코드는 비개발자를 위한 무코딩 개발 방식인 반면, 로우코드는 최소 코딩을 허용하여 확장성과 복잡한 요구사항까지 대응 가능한 개발 방식

### IV. 로우코드(Low Code) 적용 시 한계

| 관점     | 한계             | 설명                                |
|--------|----------------|-----------------------------------|
| 기능·유연성 | - 복잡한 로직 구현 한계 | - 고도화된 비즈니스 로직·알고리즘 구현 시 제약 발생    |
| 성능     | - 성능 최적화 제약    | - 플랫폼 추상화로 세밀한 튜닝 어려움             |
| 확장성    | - 대규모 시스템 한계   | - 초대형 트랜잭션·분산 처리 대응에 제약           |
| 벤더 종속  | - 플랫폼 의존성      | - 특정 로우코드 플랫폼에 종속(Vendor Lock-in) |
| 보안·통제  | - 보안 통제 한계     | - 세부 보안 정책·감사 요구 반영 어려움           |
| 품질 관리  | - 품질 편차        | - 시민 개발자 증가로 품질·표준 관리 어려움         |
| 운영     | - 운영 복잡성       | - 버전·형상·장애 원인 추적 한계               |
| 비용     | - 장기 비용 증가     | - 사용자·앱 증가 시 라이선스 비용 확대           |

- 로우코드는 개발 생산성을 높이지만, 복잡성·성능·확장성·보안 측면의 한계와 플랫폼 종속 리스크를 함께 고려해야 함

“끝”



|      |                                                                                                                                                   |     |          |
|------|---------------------------------------------------------------------------------------------------------------------------------------------------|-----|----------|
| 03   | 데이터베이스 분할                                                                                                                                         |     |          |
| 문제   | 분산 데이터베이스 시스템 구축을 위한 데이터베이스 분할에 대하여 다음 내용을 설명하시오.<br>가. 데이터베이스 분할 단위<br>나. 수평분할과 수직분할                                                             |     |          |
| 도메인  | 데이터베이스                                                                                                                                            | 난이도 | 중(상/중/하) |
| 키워드  | 데이터베이스 분할(Fragmentation), 수평분할(Horizontal Fragmentation), 수직분할(Vertical Fragmentation), 분산 투명성(Distribution Transparency), 데이터 지역성(Data Locality) |     |          |
| 출제배경 | 대용량 데이터 처리와 서비스 확장 요구 증가로 분산 데이터베이스 아키텍처가 보편화되고 있음                                                                                                |     |          |
| 참고문헌 | ITPE 서브노트, 모의고사                                                                                                                                   |     |          |
| 해설자  | 정주행 조종흥 기술사(제127회 정보관리기술사 / jongheung.cho@gmail.com)                                                                                              |     |          |

### I. 성능, 가용성, 확장성 확보를 위한, 데이터베이스 분할의 개요

|                 |                                                                                                                |                                                                                                                                |
|-----------------|----------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| 개념              | - 하나의 논리적 데이터베이스(테이블/관계)를 특정 기준에 따라 여러 개의 부분 데이터(조각, Fragment)로 나누고, 이를 서로 다른 노드(사이트)에 분산 저장·처리할 수 있도록 구성하는 기법 |                                                                                                                                |
| 분할목적            | 성능 향상<br>(Performance)                                                                                         | - 데이터가 자주 사용되는 위치(노드)에 가깝게 배치하여 원격 접근을 줄이고 응답시간을 단축.<br>- 처리 부하를 여러 노드로 분산하여 병렬 처리 및 처리량(Throughput) 향상을 도모.                   |
|                 | 데이터 지역성<br>(Locality) 확보                                                                                       | - 사용자/업무가 주로 사용하는 데이터 조각을 해당 지역 노드에 저장하여 네트워크 통신 비용 최소화를 달성.<br>- 예: 지역별 고객정보를 지역 센터에 배치하여 조회·갱신을 지역 내에서 처리                    |
|                 | 확장성<br>(Scalability) 확보                                                                                        | - 데이터와 트래픽 증가 시 노드 추가를 통해 수평 확장(scale-out)이 가능<br>- 분할 기준이 적절하면 데이터 재배포(리밸런싱) 비용 감소                                            |
|                 | 가용성 및 장애 격리                                                                                                    | - Availability / Fault Isolation<br>- 장애 발생 시 전체가 멈추는 것이 아니라 일부 조각(노드)만 영향을 받도록 설계<br>- 필요 시 복제와 결합하여 장애 복원력을 강화               |
|                 | 관리 효율 및 보안·규제 대응                                                                                               | - Manageability / Compliance<br>- 대용량 테이블을 분할하면 백업, 아카이빙, 파티션 단위 유지보수 등 운영 편의성 증가<br>- 데이터 주권/규제(예: 지역 내 저장 요구) 측면 저장 위치 통제 가능 |
| 데이터 분할과 분산 투명성의 | 분할 투명성<br>(Fragmentation Transparency)                                                                         | - 사용자는 하나의 테이블을 조회/갱신한다고 생각하지만, 시스템은 내부적으로 여러 조각에 대해 질의를 분해하고 결과를 통합<br>- 분할은 사용자에게 드러나지 않고 DBMS가 조각 관리(분해·병합)를 자동 수행          |

|    |                                               |                                                                                                                                                                                            |
|----|-----------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 관계 | 위치 투명성<br>(Location Transparency)             | <ul style="list-style-type: none"> <li>- 데이터 조각이 어느 노드에 저장되어 있는지 사용자는 알 필요가 없으며, 질의는 동일한 논리 스키마 기준으로 수행</li> <li>- 분할 이후에도 논리적 스키마는 단일 DB처럼 유지되고, 물리적 위치만 다름</li> </ul>                    |
|    | 복제 투명성<br>(Replication Transparency)<br>과의 연계 | <ul style="list-style-type: none"> <li>- 분할된 조각이 복제되는 경우, 시스템은 복제본 선택 및 동기화(정합성 유지)를 처리하고 사용자는 이를 인지하지 않는다.</li> <li>- 분할+복제 조합은 가용성과 성능을 높이지만, 정합성 제어 부담이 커짐</li> </ul>                   |
|    | 투명성 vs 복잡도<br>트레이드오프                          | <ul style="list-style-type: none"> <li>- 투명성을 높일수록(완전 자동화) 사용 편의는 올라가지만, 내부적으로는 분산 질의 최적화, 분산 트랜잭션 제어, 카탈로그 관리 등 시스템 복잡도가 증가</li> <li>- 설계 시 "투명성 수준"을 업무 요구(성능/일관성/운영성)에 맞게 결정</li> </ul> |

- 데이터베이스 분할은 데이터 지역성과 확장성을 확보하여 성능·가용성을 높이는 핵심 설계 기법이며, 동시에 사용자가 분산을 인지하지 않도록 하는 분할·위치·복제 투명성 구현의 기반이 됨.

## II. 데이터베이스 분할 단위

### 가. 분할 단위의 개념 및 유형

| 개념                  | <ul style="list-style-type: none"> <li>- 데이터베이스를 어떤 "객체 수준"에서 나눌 것인지를 의미</li> <li>- 분산 DB 설계에서 성능(통신 비용/병렬성), 정합성(트랜잭션 범위), 관리성(운영 복잡도)을 좌우하는 핵심 결정 요소</li> </ul> |                                      |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|
| 유형                  | 특징                                                                                                                                                                | 설명                                   |
| 데이터베이스<br>스키마 단위 분할 | 업무 영역 기준 분리                                                                                                                                                       | - 업무·서비스 단위로 DB 인스턴스를 분리하여 책임 경계 명확화 |
| 테이블 단위 분할           | 테이블 기준 분리                                                                                                                                                         | - 테이블을 기준으로 노드별 분산 배치하여 관리 용이성 확보    |
| 레코드(튜플) 단위 분할       | 행 기준 분산                                                                                                                                                           | - 특정 분할 기준에 따라 레코드를 여러 조각으로 분산 저장    |
| 속성(컬럼) 단위 분할        | 컬럼 기준 분리                                                                                                                                                          | - 접근 빈도 및 성격에 따라 컬럼을 분리하여 I/O 최적화    |
| 혼합 단위 분할            | 복합 분할 적용                                                                                                                                                          | - 수평·수직 분할을 조합하여 성능과 관리성 동시 확보       |
| 파티션/샤드 단위 분할        | 물리 구현 중심                                                                                                                                                          | - 파티션·샤딩을 활용한 물리적 분산으로 확장성 강화        |

### 나. 분할 단위 선정 시 고려요소

| 구분    | 고려요소        | 설명                            |
|-------|-------------|-------------------------------|
| 업무 특성 | - 데이터 접근 패턴 | - 조회·갱신·집계 빈도에 따른 분할 단위 결정    |
|       | - 트랜잭션 경계   | - 동일 트랜잭션 내 데이터의 동일 노드 배치 필요성 |
|       | - 조인 발생 빈도  | - 분산 조인 최소화를 위한 분할 기준 정합성     |

|        |              |                             |
|--------|--------------|-----------------------------|
| 성능 관점  | - 데이터 지역성    | - 사용자 및 처리 위치 기반 데이터 배치 고려  |
|        | - 네트워크 비용    | - 원격 접근 감소를 통한 통신 비용 최소화    |
|        | - 병렬 처리 효과   | - 노드 간 부하 분산을 통한 처리량 향상 가능성 |
| 확장 관점  | - 데이터 및 증가율  | - 데이터 성장에 따른 수평 확장 용이성      |
|        | - 노드 확장 대응성  | - 노드 추가 시 데이터 재분배 용이성       |
|        | - 분할 기준 안정성  | - 분할 기준 변경에 따른 영향도 최소화      |
| 일관성 관점 | - 정합성 요구 수준  | - 강한 일관성 또는 최종 일관성 요구 반영    |
|        | - 분산 트랜잭션 영향 | - 2PC 등 분산 트랜잭션 발생 가능성 고려   |
|        | - 복제 전략 연계   | - 분할과 복제 결합 시 충돌 관리 부담      |
| 보안·규제  | - 민감정보 분리    | - 개인정보 및 중요정보의 물리적 분리 필요성   |
|        | - 데이터 주권     | - 지역별 저장·처리 규제 대응           |
|        | - 접근통제 범위    | - 권한·감사·암호화 적용 범위 최소화       |
| 운영 관점  | - 관리 복잡도     | - 분할 단위 세분화에 따른 운영 부담       |
|        | - 백업·복구 단위   | - 장애 복구 및 백업 단위 설정 용이성      |
|        | - 리밸런싱 비용    | - 데이터 재배포 시 운영 비용 및 영향도     |

- 분할 단위는 업무 특성과 데이터 접근 패턴에 따라 데이터베이스, 테이블, 레코드, 속성 수준에서 선택되며, 실무에서는 혼합 분할과 물리적 파티셔닝을 통해 분산 데이터베이스의 성능과 확장성을 동시에 확보

### III. III. 데이터베이스의 분할 방식

#### 가. 수평분할

|                  |                                                             |    |
|------------------|-------------------------------------------------------------|----|
| 개념               | - 하나의 테이블을 <b>행(Row, 튜플)</b> 기준으로 여러 조각으로 분리하는 방식           |    |
| 분할 기준            | - 범위(Range), 해시(Hash), 리스트(List/지역/코드), 조건(Predicate) 기반 분할 |    |
| 분할 기법            |                                                             | 설명 |
| 범위(Range) 분할     | - 숫자, 날짜 등 값의 범위를 기준으로 분할 (예: 월별 매출)                        |    |
| 해시(Hash) 분할      | - 해시 함수를 적용해 데이터를 균등하게 배분                                   |    |
| 리스트(List) 분할     | - 특정 목록 값을 기준으로 분할 (예: 지역별 코드)                              |    |
| 조건(Condition) 분할 | - 컬럼 기준 분리                                                  |    |
| 복합(Composite) 분할 | - 위 기법들을 혼합하여 분할하는 기법                                       |    |

#### 나. 수직분할

|                |                                                                                    |                                         |
|----------------|------------------------------------------------------------------------------------|-----------------------------------------|
| 개념             | - 테이블의 <b>컬럼(Column)</b> 을 기준으로 나누어 별도의 테이블로 분리하고, <b>기본키(PK)</b> 를 통해 관계를 유지하는 방식 |                                         |
| 분할 기준          | - 컬럼 접근 빈도, 컬럼 크기(BLOB/CLOB), 민감정보 여부, 업무 기능별 사용 컬럼 군집                             |                                         |
| 분할 기법          | 특징                                                                                 | 설명                                      |
| 접근 빈도 기반 수직분할  | - 조회 패턴 중심 분리                                                                      | - 자주 조회되는 컬럼과 드물게 조회되는 컬럼을 분리하여 I/O 최적화 |
| 기능(업무) 기반 수직분할 | - 업무 기능별 분리                                                                        | - 서로 다른 업무 기능에서 사용하는 컬럼 그룹을 기준으로 분리     |

|                |               |                                     |
|----------------|---------------|-------------------------------------|
| 민감정보 기반 수직분할   | - 보안 중심 분리    | - 개인정보·민감정보 컬럼을 별도 테이블로 분리하여 보안 강화  |
| 데이터 크기 기반 수직분할 | - 대용량 컬럼 분리   | - BLOB-CLOB 등 대용량 컬럼을 분리하여 성능 저하 방지 |
| 갱신 특성 기반 수직분할  | - 변경 빈도 기준 분리 | - 자주 변경되는 컬럼과 거의 변경되지 않는 컬럼을 분리     |
| 접근 권한 기반 수직분할  | - 권한 통제 중심    | - 사용자/역할별 접근 권한이 다른 컬럼을 분리 저장       |
| 혼합 기준 수직분할     | - 다중 기준 적용    | - 접근 빈도·보안·크기 등을 종합 고려한 복합 분리       |

#### 다. 수평 분할과 수직 분할 비교

| 비교 기준   | 수평분할(Horizontal)                 | 수직분할(Vertical)                     |
|---------|----------------------------------|------------------------------------|
| 분할 기준   | - 행(Row) 기준 분리                   | - 컬럼(Column) 기준 분리                 |
| 목적 중심   | - 확장성·부하분산·지역성 확보 중심             | - I/O 최적화·보안 분리·캐시 효율 중심           |
| 대표 적용   | - 샤딩(Shard), 기간/지역/고객군 분산        | - 핵심/비핵심 컬럼 분리, 민감정보 분리            |
| 성능 효과   | - 분할 키 기반 질의에서 병렬 처리 및 응답 개선     | - 불필요한 컬럼 로딩 감소로 응답 개선             |
| 비용 요인   | - 분산 집계·조인·스캔 비용 증가 가능성          | - PK 기반 재결합(조인) 비용 증가 가능성          |
| 트랜잭션 영향 | - 조각 간 트랜잭션 시 분산 트랜잭션 증가 가능성     | - 다중 조각 갱신 시 동기화 부담 증가 가능성         |
| 운영 관점   | - 리밸런싱·핫샤드·데이터 편향 관리 필요성         | - 스키마 변화·인덱스/PK 동기화 관리 필요성         |
| 보안/규제   | - 저장 위치 통제(리전/센터) 측면 대응 용이성      | - 민감정보 물리 분리 및 접근통제 강화 용이성         |
| 적합 환경   | - 대용량/고성장 데이터, 사용자 분산, 트래픽 집중 업무 | - 컬럼 폭이 넓고 선택적 조회가 많은 업무, 보안 요구 업무 |
| 결합 전략   | - 수평+수직 혼합 분할을 통한 동시 최적화 가능성     | - 수직+수평 혼합 분할을 통한 동시 최적화 가능성       |

#### IV. 데이터베이스 분할 설계시 고려 사항

| 구분    | 고려 사항     | 설명                         |
|-------|-----------|----------------------------|
| 업무 관점 | 업무 처리 특성  | 조회·갱신·집계 중심 업무 특성 반영       |
|       | 데이터 접근 패턴 | 사용자·시스템별 데이터 접근 빈도 고려      |
|       | 트랜잭션 경계   | 동일 트랜잭션 데이터의 동일 노드 배치 필요성  |
| 성능 관점 | 데이터 지역성   | 사용자 및 처리 위치 기반 데이터 배치 고려   |
|       | 네트워크 비용   | 원격 데이터 접근 최소화를 통한 통신 비용 절감 |
|       | 병렬 처리 효과  | 노드 분산을 통한 처리량 및 응답성 향상     |
| 구조 관점 | 분할 단위 적절성 | 테이블·레코드·속성 단위 선택의 적절성      |
|       | 분할 기준 안정성 | 분할 기준 변경에 따른 영향도 최소화       |

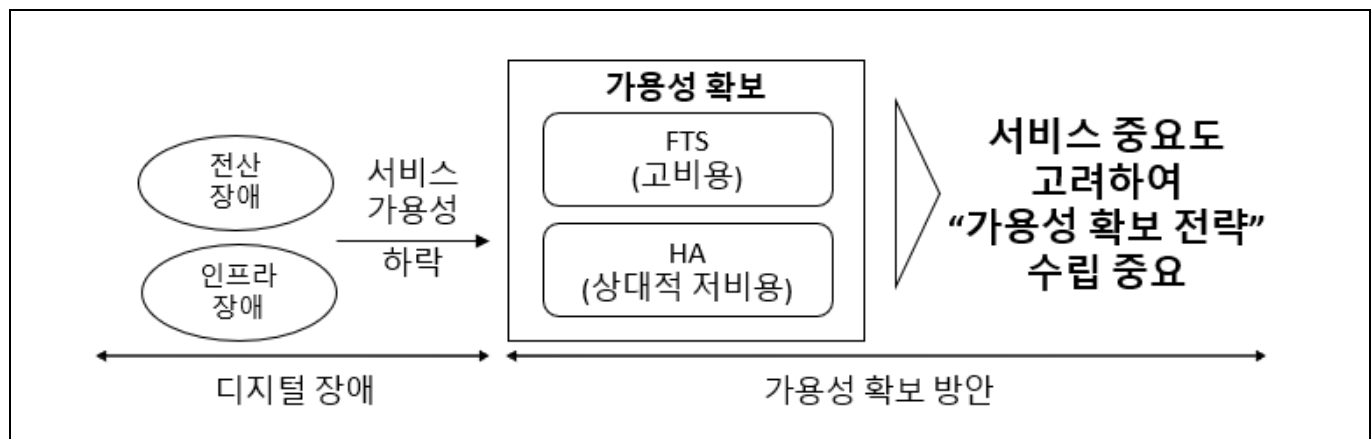
|        | 재구성 가능성    | 원본 테이블로의 재결합 가능 여부      |
|--------|------------|-------------------------|
| 일관성 관점 | 정합성 요구 수준  | 강한 일관성 또는 최종 일관성 요구 반영  |
|        | 분산 트랜잭션 영향 | 분산 트랜잭션 발생 가능성 및 성능 영향  |
|        | 복제 전략 연계   | 분할과 복제 결합 시 충돌 관리 부담    |
| 확장 관점  | 데이터 증가 대응  | 데이터 성장에 따른 수평 확장 용이성    |
|        | 노드 확장성     | 노드 추가 시 데이터 재배포 용이성     |
|        | 리밸런싱 비용    | 데이터 재분배 시 운영 비용 및 영향도   |
| 보안·규제  | 민감정보 보호    | 개인정보·중요정보의 분리 및 암호화 필요성 |
|        | 데이터 주권     | 지역별 저장·처리 규제 대응         |
|        | 접근 통제      | 역할·권한 기반 접근 제어 적용 용이성   |
| 운영 관점  | 관리 복잡도     | 분할 단위 세분화에 따른 운영 부담     |
|        | 백업·복구 전략   | 장애 대응 및 복구 단위 설정 용이성    |
|        | 모니터링 및 감사  | 분산 환경에서의 추적·감사 가능성      |

- 데이터베이스 분할 설계는 업무 특성, 성능, 구조적 안정성, 일관성, 확장성, 보안 및 운영 관점을 종합적으로 고려하여 시스템 품질을 균형 있게 확보해야 함.

“끝”

|      |                                                                                                                        |     |           |
|------|------------------------------------------------------------------------------------------------------------------------|-----|-----------|
| 04   | FTS(Fault Tolerant System), HA(High Availability)                                                                      |     |           |
| 문제   | 가용성 보장에 대하여 다음 내용을 설명하시오.<br>가. FTS(Fault Tolerant System) 구현 방법<br>나. HA(High Availability) 구현 방법<br>다. FTS와 HA 비교 설명 |     |           |
| 도메인  | 컴퓨터구조                                                                                                                  | 난이도 | 중 (상/중/하) |
| 키워드  | 무중단, Failover, 이중화, Mirror/Hot/Warm/Cold Site                                                                          |     |           |
| 출제배경 | 인프라 관점에서 연속성 보장 기술에 대한 지식 확인                                                                                           |     |           |
| 참고문헌 | ITPE 기술사회 자료                                                                                                           |     |           |
| 해설자  | NS반 백현 기술사(제 122회 정보관리기술사 / snuoo@naver.com)                                                                           |     |           |

### I. IT 서비스 연속성 및 가용성 보장을 위한 가용성 확보 전략 개요



- 국내 대규모 전산 및 인프라 장애로 IT 서비스에서 연속성 및 가용성 확보는 디지털 비즈니스의 생존과 직결된 핵심 전략으로 요구되고 있어, 가용성 확보 전략 수립 및 체계 구축이 필수 요건

### II. FTS(Fault Tolerant System) 구현 방법

#### 가. FTS(Fault Tolerant System) 구현 단계

|      |                                                                 |                                                                    |
|------|-----------------------------------------------------------------|--------------------------------------------------------------------|
| 개념   | - 하드웨어나 소프트웨어의 결함, 오동작, 오류 등이 발생하더라도 규정된 기능을 지속적으로 수행할 수 있는 시스템 |                                                                    |
| 목표   | 무중단 서비스                                                         | - 100% 가용성을 확보                                                     |
| 단계   | 1) 결함 감지                                                        | - Ping/Echo, Heartbeat, Exception 처리                               |
|      | 2) 결함 진단                                                        | - 모니터링, 비교, 시뮬레이션, 오류 비트                                           |
|      | 3) 결함 통제/복구                                                     | - 중복(Redundancy), 교체, 격리(Isolation)                                |
| 복구방법 | 후향 복구<br>(Backward Recovery)                                    | - 시스템에 오류가 발생했을 때, 시스템의 상태를 오류가 발생하기 이전의 검사점(Checkpoint)으로 되돌리는 방식 |
|      | 전향 복구<br>(Forward Recovery)                                     | - 시스템에서 결함이 발생한 부분을 수정하거나 우회하여 오류가 없는 다음 정상 상태로 진행시키는 방식           |

- FTS 설계시 처리방식, 결함허용 정도, 후향복구 및 전향복구 등을 복합적으로 고려

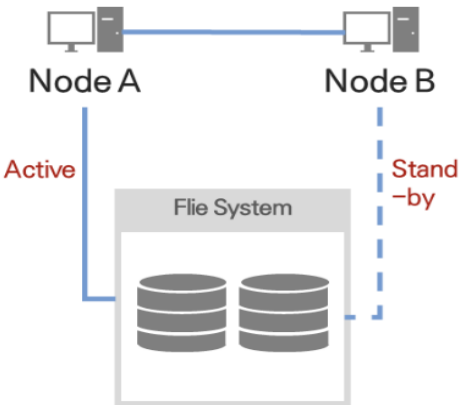
## 나. FTS(Fault Tolerant System) 구현 기술

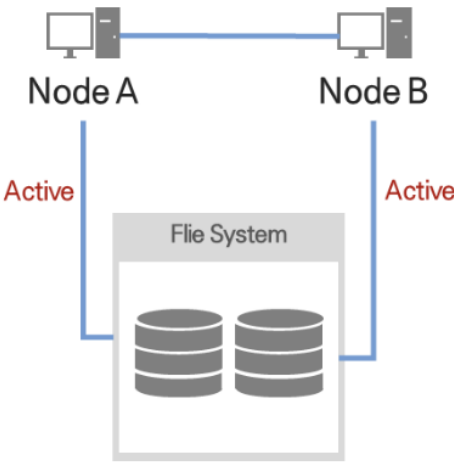
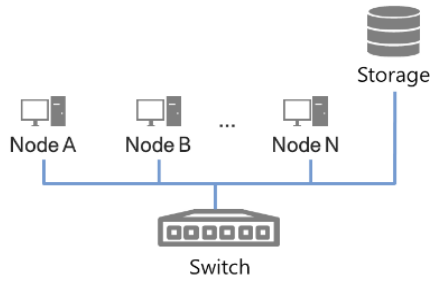
| 구분       | 구현기술                              | 설명                                                                                                     |
|----------|-----------------------------------|--------------------------------------------------------------------------------------------------------|
| 하드웨어 측면  | - Triple modular Redundancy(TMR)  | - 하드웨어를 세개 중복하고 그 출력을 비교하여 2개 이상의 같은 출력을 TMR의 출력으로 선택하는 기술                                             |
|          | - Duplication with comparison     | - 하드웨어를 두개 중복하여 그 출력을 비교함으로써 결함을 감지하는 기법. 결함 감지 기능만 수행 가능                                              |
|          | - Watchdog Timer                  | - 주기적으로 timer를 초기화 시키며 결함을 감지하는 기법                                                                     |
| 정보 측면    | - Parity Code                     | - 정보가 2진수로 표시될 때 한 정보에 1의 개수가 홀수개 또는 짝수개 인지를 알리는 여분의 정보를 추가하는 방법                                       |
|          | - Checksum                        | - 한 정보 블록의 정보 내용 합을 정보 블록에 추가하는 기법. 정보 결함 감지 기능 수행                                                     |
| 소프트웨어 측면 | - Check pointing                  | - 소프트웨어 실행중에 검사 시점을 설정하여 오류가 발생하는 지를 검사하여, 이상이 발견되면 검사시점으로 돌아가 재수행                                     |
|          | - Distributed recovery block(DRB) | - Recovery block을 분산 환경으로 확장 적용하여 하드웨어 결함과 소프트웨어 결함을 동일한 방법으로 극복하는 방법                                  |
|          | - N Self-checking programming     | - 한 부품이 주(Primary) 역할을 수행하는 동안, 다른 부품들은 대기하며 자신의 상태를 체크, 주 부품의 결함 여부를 감시 및 주 부품 장애 시 다른 부품이 승격하여 역할 수행 |

- 가용성 확보를 위해 FTS는 결함 발생 시에도 서비스의 끊김 없는 지속성을 확보하는 것이 목적

## III. 시스템 중복 배치를 통한 가용성 확보 방법, HA(High Availability)

## 가. HA(High Availability)

|    |                                                                     |                                                                                                                                                                                                                                                                                |
|----|---------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 개념 | - 장애 발생 시, 서비스 중단 시간 최소화를 위해, Failover(장애 조치)하여 목표 수준의 가용성을 확보하는 기술 |                                                                                                                                                                                                                                                                                |
| 목표 | 고가용성 확보                                                             | - 99.999%(Five Nines) 이상의 가용성을 확보                                                                                                                                                                                                                                              |
| 특징 | Failover                                                            | - 주 시스템에 장애가 발생했을 때, 예비 시스템으로 자동 전환하여 서비스를 지속하는 기능                                                                                                                                                                                                                             |
|    | 이중화                                                                 | - 동일한 기능을 가진 시스템이나 장비를 여러 개 준비해 두어 하나가 고장나도 다른 하나가 즉시 대체할 수 있도록 구성                                                                                                                                                                                                             |
| 유형 | hot standby                                                         | <div style="text-align: center;">  </div> <div style="margin-top: 10px;">             - 장애 시에만 백업시스템 접근<br/>             - 가동 시스템과 평상시 대기 상태 또는 개발 시스템으로 운영되는 백업 시스템으로 구성           </div> |

|  |                   |                                                                                    |                                                                                                                                                                               |
|--|-------------------|------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | mutual takeover   |  | <ul style="list-style-type: none"> <li>- 다른 시스템 장애 시 2 개의 업무 수행</li> <li>- 2 개의 시스템이 각각의 고유한 가동 업무 서비스 수행</li> <li>- 장애 발생 시 상태 시스템의 자원을 Failover 하여 동시에 2 개 업무 수행</li> </ul> |
|  | concurrent access |  | <ul style="list-style-type: none"> <li>- 업무 나누어 병렬처리, 전체 시스템 active</li> <li>- 여러 개의 시스템을 동시에 나누어 병렬처리</li> <li>- HA 에 참여하는 시스템 전체가 Active 한 상태로 업무수행</li> </ul>              |

## 나. HA(High Availability) 구현 기술

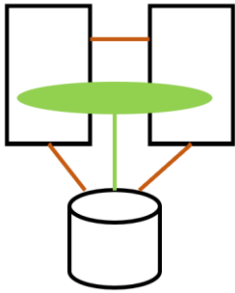
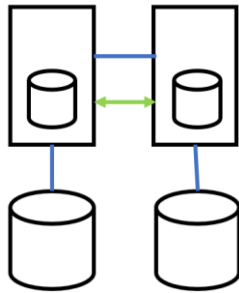
| 구분    | 구현기술                                | 설명                                                                                            |
|-------|-------------------------------------|-----------------------------------------------------------------------------------------------|
| 요구사항  | - RAS                               | - Reliability, Availability, Serviceability                                                   |
|       | - Dynamic Configuration And Upgrade | - 유지보수 및 환경 변화에 유연한 대응을 위해 동적 설정 및 업그레이드 기능                                                   |
|       | - Disaster Recovery                 | - 장애 발생 후 복구 기능                                                                               |
| 구성 유형 | - Hot Standby                       | - 가동시스템과 평상시 대기상태 또는 개발시스템으로 운영 되는 백업시스템으로 구성                                                 |
|       | - Mutual Takeover                   | - 2개 시스템이 각각의 고유한 가동 업무 서비스를 수행하다가 한 서버에 장애가 발생하면 상대 시스템의 자원을 Failover 하여 동시에 2개의 업무를 수행하는 방식 |
|       | - Concurrent Access                 | - 여러 개의 시스템이 동시에 업무를 나누어 병렬 처리하는 방식으로 HA 에 참여하는 시스템 전체가 Active 한 상태로 업무를 수행                   |

- HA 는 FTS 의 가용성 확보의 목적은 같지만, 구축 및 유지보수 비용의 차이, 복구 방식에서 차이가 존재



#### IV. FTS와 HA의 비교 설명

##### 가. FTS와 HA의 개념 비교 설명

| 구분    | FTS(Fault Tolerant System)                                                        | HA(High Availability)                                                               |
|-------|-----------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| 개념    | - 하드웨어 또는 소프트웨어의 결함, 오 동작, 오류 등이 발생하더라도 설계상 명시된 기능을 지속적으로 수행할 수 있는 시스템            | - 두 대 이상의 시스템을 하나의 클러스터로 묶어서 한 시스템 장애 시 다른 시스템이 신속하게 서비스를 Failover 하는 시스템 구조        |
| 개념도   |  |  |
| 필요성   | - 데이터의 무결성과 일관성 유지<br>- 시스템 고장으로 인한 경제, 인명손실 방지                                   | - 가용성 극대화<br>- 고가용성으로 비즈니스 연속성 확보                                                   |
| 이중화   | - 복제(Replication)<br>- 다중화(Redundancy)<br>- 다양화(Diversification)                  | - Hot Stand by<br>- Mutual Takeover<br>- Concurrent Access                          |
| 복구 절차 | 1) 결함 감지<br>2) 결함 진단<br>3) 결함 통제/복구                                               | 1) 장애 발생<br>2) 장애 감지<br>3) 자원 이전<br>4) 재기동                                          |

##### 나. FTS와 HA의 성능 및 Spec 비교

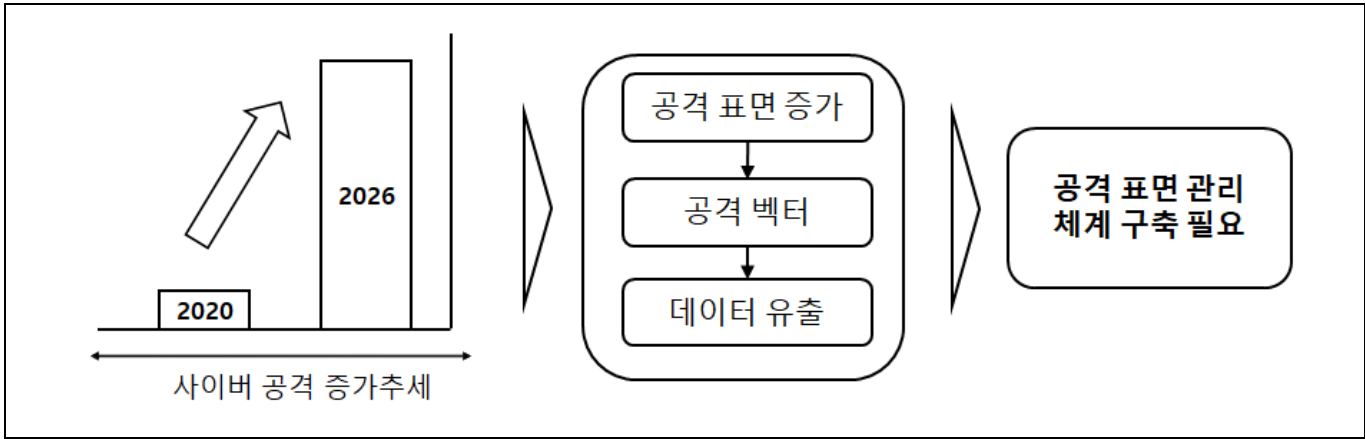
| 구분            | FTS     | HA      |
|---------------|---------|---------|
| Failover Time | 0초      | 30~400초 |
| 동시성 유지보수      | 필요      | 불필요     |
| 시스템 비용        | 10~20배  | 2~3배    |
| 어플리케이션        | 제한적     | 범용App   |
| OS            | 전용OS    | 범용OS    |
| HW            | 전용 하드웨어 | 범용 하드웨어 |

- FTS 시스템이 높은 가용성을 보여주지만 비용이 매우 커 비즈니스 중요도에 따라 차등하여 FTS와 HA 기법 적용이 CAPEX & OPEX에 유리

“끝”

|      |                                                                                                                                                                                                               |     |           |
|------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----------|
| 05   | 공격 표면(Attack Surface)                                                                                                                                                                                         |     |           |
| 문제   | IT 인프라 확장에 따른 사이버 위협에 대하여 다음 내용을 설명하시오.<br>가. 공격 표면(Attack Surface)과 공격 벡터(Attack Vector)<br>나. 측면 이동(Lateral Movement)의 단계별 메커니즘과 주요 기법                                                                      |     |           |
| 도메인  | 보안                                                                                                                                                                                                            | 난이도 | 중 (상/중/하) |
| 키워드  | 진입점, 취약점, 내부망 이동, 데이터 유출, API, 공격표면 관리                                                                                                                                                                        |     |           |
| 출제배경 | DX, AX 가 지속화 됨에 따라 기업의 데이터 유출 사건 증가로 관련 토픽 출제                                                                                                                                                                 |     |           |
| 참고문헌 | <a href="https://www.sentinelone.com/ko/cybersecurity-101/cybersecurity/attack-surface-vs-attack-vector/">https://www.sentinelone.com/ko/cybersecurity-101/cybersecurity/attack-surface-vs-attack-vector/</a> |     |           |
| 해설자  | NS반 백현 기술사(제 122회 정보관리기술사 / snuoo@naver.com)                                                                                                                                                                  |     |           |

I. IT 인프라 확장에 따른 사이버 위협 공격 현황 개요



- IT 인프라가 클라우드 기반으로 전환이 가속화되면서 확장성이 증가되고 있고, 그에 따른 공격 표면이 증가됨에 따라 사이버 공격이 증가됨에 따라 지속적인 공격 표면을 관리할 수 있는 체계 구축이 필요

II. 공격 표면(Attack Surface)과 공격 벡터(Attack Vector)

가. 공격 표면(Attack Surface) 설명

|     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|-----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 개념  | - 위협 행위자가 시스템이나 네트워크를 침해하기 위해 악용할 수 있는 모든 가능한 진입점                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| 개념도 | <p>The diagram shows three concentric semi-circular perimeters representing different security models. The innermost is the 'Traditional Perimeter' containing 'Endpoints' and 'Servers'. The middle is the 'Modern Perimeter' containing 'Identity', 'Applications', 'Websites', and 'Cloud Workload'. The outermost is the 'Expanding Perimeter' containing 'Data', 'Social Media', 'Certificates/Domains', 'SaaS', 'Collaboration Tools', 'IoT', 'Mobile', and 'Digital Supply Chain'. Various icons represent different types of assets and attack vectors within these perimeters.</p> |

|    |          |                                     |
|----|----------|-------------------------------------|
| 유형 | - 물리적 표면 | - 데이터 센터, 엔드포인트 기기(PC, 모바일), USB 포트 |
|    | - 디지털 표면 | - 열려 있는 포트, 도메인, 공개 API, 취약한 소프트웨어  |

- 공격자는 공격 표면을 식별하여 공격 경로 수단으로 활용

#### 나. 공격 벡터(Attack Vector) 설명

|     |                                               |                                          |
|-----|-----------------------------------------------|------------------------------------------|
| 개념  | - 공격자가 공격 표면에 접근하여 취약점을 악용하기 위해 사용하는 경로 또는 수단 |                                          |
| 개념도 |                                               |                                          |
| 유형  | - 어플리케이션 벡터                                   | - SQL Injection, XSS, API Exploitation   |
|     | - 네트워크 벡터                                     | - DDoS, MitM, Brute Force, Dictionary    |
|     | - 인적/사회적 벡터                                   | - Phishing, Smishing, Social Engineering |
|     | - 시스템/구조적 벡터                                  | - Supply Chain Attack, Zero-day Exploit  |

- 공격 벡터를 통해 공격자가 내부망에 침입 후 데이터 유출을 위해 지속적인 스캔 및 시스템을 이동하여 데이터를 유출

### III. 공격 표면을 활용한 공격 벡터, 레터럴 무브먼트(Lateral Movement)

#### 가. 레터럴 무브먼트(Lateral Movement) 개념 설명

|     |                                                                        |                                                                      |
|-----|------------------------------------------------------------------------|----------------------------------------------------------------------|
| 개념  | - 공격자가 내부 네트워크에 진입한 후, 목표 데이터가 있는 서버나 관리자 권한을 탈취하여 다른 시스템으로 이동하는 공격 기법 |                                                                      |
| 개념도 |                                                                        |                                                                      |
| 절차  | - 권한 상승                                                                | - 최초 침투한 일반 계정에서 관리자 권한을 획득하여 접근 가능한 시스템 범위를 넓히는 단계                  |
|     | - 데이터 탐색                                                               | - 내부망의 파일 서버, DB, Active Directory(AD) 등 데이터 스캔                      |
|     | - 내부 이동                                                                | - 인증정보(Credential) 훔친 후 내부망 다른 시스템 이동<br>- 패스 더 해시(Pass-the-Hash) 공격 |
|     | - 데이터 유출                                                               | - 타겟서버에 개인정보, 기밀정보 유출                                                |

- 공격 벡터를 통해 내부망 진입 후 데이터 수집 및 데이터 유출을 지속적으로 수행하는 API 공격 기법

#### 나. 레터럴 무브먼트(Lateral Movement) 공격 기법

| 구분             | 공격기법                  | 설명                                    |
|----------------|-----------------------|---------------------------------------|
| 계정 인증<br>정보 탈취 | Password Dumping      | - 메모리(LSASS)나 OS 파일에 저장된 평문 비번/해시를 추출 |
|                | Pass-the-Hash (PtH)   | - NTLM 해시값을 그대로 사용하여 실제 비밀번호 없이 인증 통과 |
|                | Pass-the-Ticket (PtT) | - Kerberos 티켓(TGT/TGS)을 가로채 시스템 권한 획득 |
| 원격 서비스<br>악용   | WMI 악용                | - 관리 인터페이스를 통해 원격으로 프로세스 생성 및 실행      |
|                | PowerShell Remoting   | - WinRM 서비스를 통해 원격 셸 세션 획득 및 명령 수행    |
|                | Psexec                | - 정상적인 원격 관리 도구를 활용한 대화형 명령 프롬프트 실행   |
| 내부 취약점<br>공격   | SMB 취약점               | - 파일 공유 프로토콜의 취약점을 악용하여 RCE(원격 코드 실행) |
|                | RDP 취약점               | - 원격 데스크톱 서비스의 취약점을 통한 인증 우회 및 침투     |
|                | C2 Framework          | - 정찰, 권한 상승, 측면 이동 단계를 GUI/스크립트로 자동화  |
|                | Internal Recon        | - 내부 네트워크 스캐닝을 통해 추가 공격 표면 식별         |

- 공격 표면과 공격 벡터를 지속적으로 식별 및 관리해서 관리 체계 구축이 필요

#### IV. 공격 표면 및 공격 벡터 관리를 위한 모니터링 체계, ASM(Attack Surface Management)

| 개념  | - 인터넷에서 수집할 수 있는 모든 정보를 검색, 나열, 분류, 분석, 우선순위 지정 및 모니터링 하고, 외부 디지털 자산을 검색하여 민감한 데이터에 대해 조직에 알리는 프로세스                                                                                                                                                                                                            |                                                                                   |
|-----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| 개념도 | <pre> graph LR     A[인터넷 정보 수집<br/>디지털 발자국] --&gt; B[IT자산 나열<br/>IT자산 분류]     B --&gt; C[IT자산<br/>분석]     C --&gt; D[Risk<br/>우선순위 지정]     D --&gt; E[지속적인<br/>모니터링]     E -- "위험 감지/식별" --&gt; F[조직의 SYSTEM]     F --- G["Alarm"]     F --- H["“Zero Trust Model” 적용<br/>불필요한 SW, HW 비활성화(악용 진입점 차단)"] </pre> |                                                                                   |
| 유형  | CAASM                                                                                                                                                                                                                                                                                                          | - 보안팀이 사이버 보안 자산 가시성과 취약성 문제를 해결할 수 있도록 지원하는 공격 표면 관리 기술                          |
|     | EASM                                                                                                                                                                                                                                                                                                           | - 알려지지 않은 외부 자산 및 네트워크 취약성을 관리하는 공격 표면 관리 기술                                      |
|     | DRPS                                                                                                                                                                                                                                                                                                           | - 사이버 공격의 정찰 단계의 공격 대응 위한 관리 기술<br>- 우선순위에 따라 디지털 공간 전체에서 위험 식별, 우선순위 지정, 해결하는 방식 |

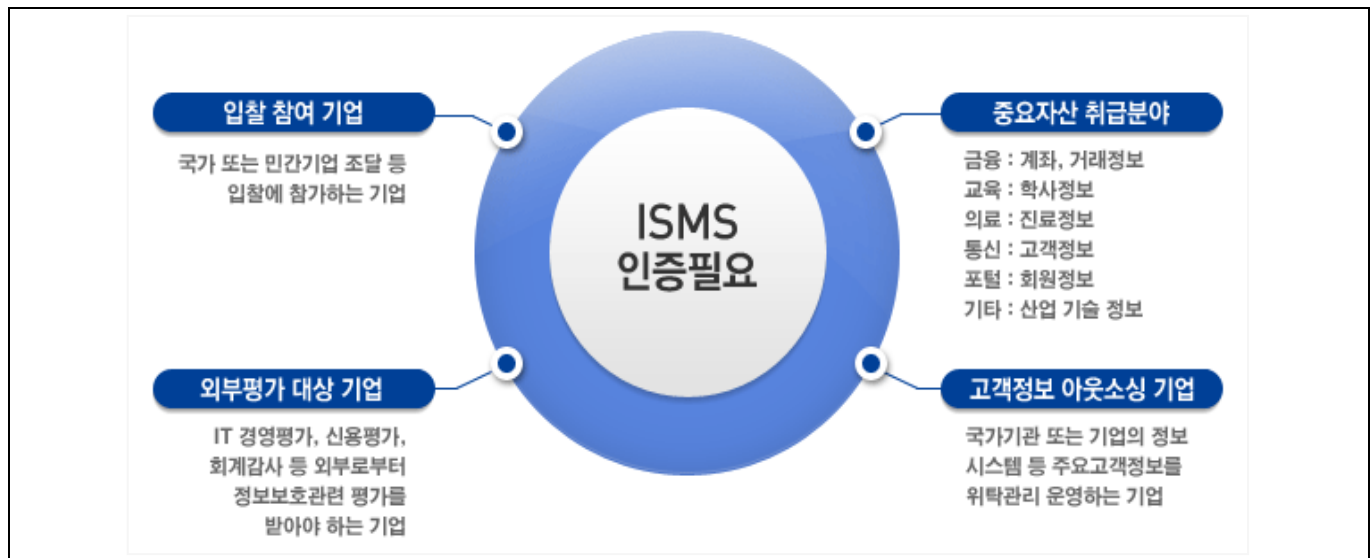
- 공격 표면 관리를 통해 공격 표면을 최소화하여 정보시스템의 데이터 보호를 통해 신뢰성 확보가 가능

“끝”

|      |                                                                                                                                                                                                                |     |          |
|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|----------|
| 06   | 정보보호 관리체계(ISMS)                                                                                                                                                                                                |     |          |
| 문제   | <p>최근 보안과 관련된 사고 및 이슈의 빈번한 발생으로 정보보호를 위한 관리체계에 대한 중요성이 부각되고 있다. 다음 내용을 설명하시오.</p> <p>가. 정보보호 관리체계(ISMS)의 인증 영역과 법적 근거</p> <p>나. 정보보호 관리체계(ISMS)의 관리 과정</p> <p>다. ISMS-P 간편인증 제도</p> <p>라. ISMS-P 제도의 강화 방안</p> |     |          |
| 도메인  | 보안                                                                                                                                                                                                             | 난이도 | 상(상/중/하) |
| 키워드  | <b>ISMS</b> : 최초심사, 재심사, 사후관리, 갱신심사, 정보보호관리과정, 문서화, 정보보호대책<br><b>ISMS-P</b> : 중소기업기본법, 인증수수료, 인증기간                                                                                                             |     |          |
| 출제배경 | ISMS, ISMS-P의 기본 지식 확인                                                                                                                                                                                         |     |          |
| 참고문헌 | ITPE 기술사회 자료집                                                                                                                                                                                                  |     |          |
| 해설자  | 정상반 정상 기술사(제 124회 정보관리기술사 / itpe_peak@naver.com)                                                                                                                                                               |     |          |

## I. 정보보호 관리체계(ISMS)의 개요

### 가. 정보보호 관리체계(ISMS)의 개념



- 정보통신망 안전성 확보를 위해 수립/운영하고 있는 기술적/물리적 보호조치 등 종합 관리체계에 대한 인증제도

### 나. 인증 영역과 법적 근거 설명

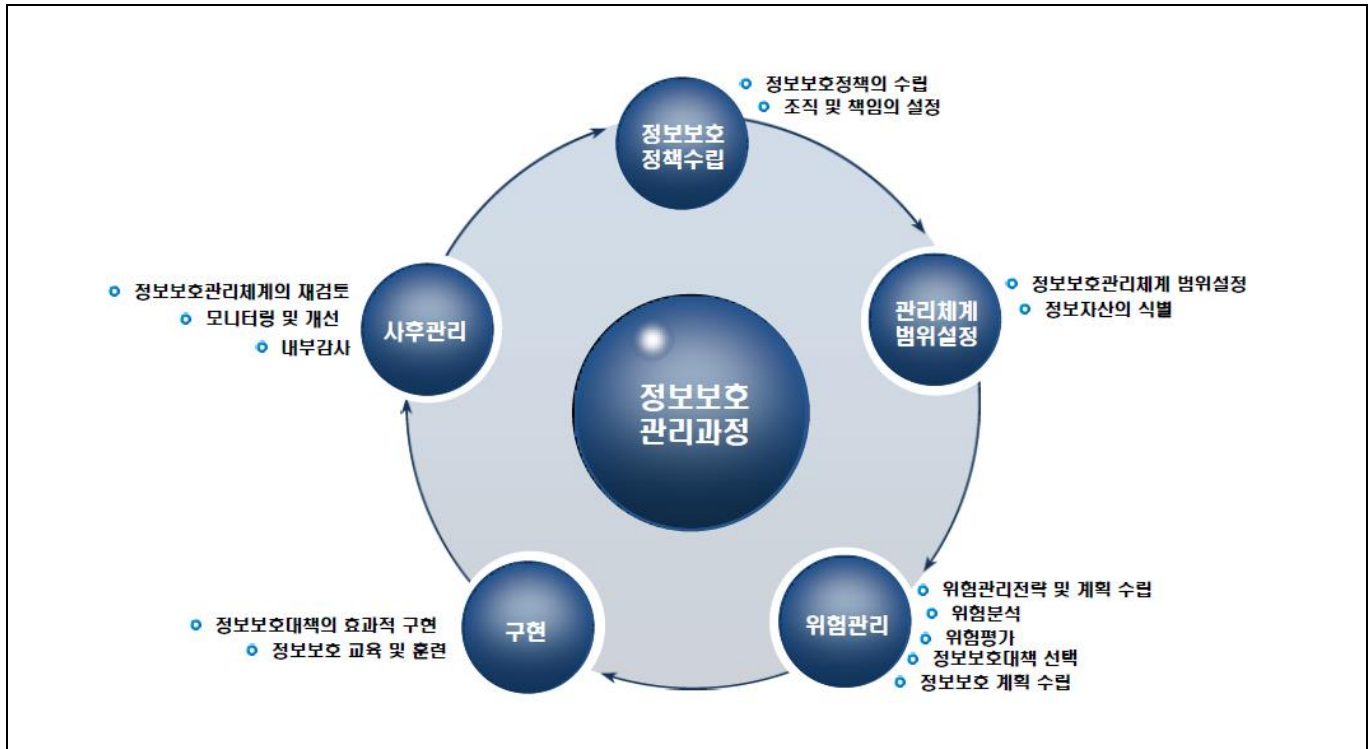
| 구분   | 항목           | 설명                                                                                                                                                             |
|------|--------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 인증영역 | 관리과정(12개 항목) | <p>- <b>수립 및 운영</b> : 경영진의 참여하에 정보보호 정책을 수립하고, 인증 범위를 설정하여 자산 식별 및 위험 평가를 수행</p> <p>- <b>사후관리</b> : 내부 감사 및 경영진 검토를 통해 발견된 문제점을 개선하고, 관리체계가 지속적으로 유지되는지 확인</p> |
|      | 보호대책(64개 항목) | - <b>정책, 조직, 자산관리</b> : 정보보호 조직 구성, 인적 보안(채용/퇴직 관리), 중요 자산의 분류 및 관리 등 기반 인프라를 구축                                                                               |

|      |                     |                                                                                                                                                                                                                                          |
|------|---------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 법적근거 |                     | <ul style="list-style-type: none"> <li>- 접근제어 : 사용자 계정 관리, 비밀번호 정책, 네트워크 접근 제한 등 인가된 사용자만 정보에 접근하도록 통제</li> <li>- 암호화 및 운영 보호 : 중요 데이터 전송·저장 시 암호화 적용, 로그 관리, 백업 및 복구, 악성코드 대응 등 기술적 보안을 이행</li> </ul>                                   |
|      | 정보통신망법 제47조 제2항     | <ul style="list-style-type: none"> <li>- 인증의무</li> <li>- 일정 요건을 갖춘 정보통신서비스 제공자는 과학기술정보통신부 장관으로부터 정보보호 관리체계의 인증을 의무적으로 받아야 함.</li> </ul>                                                                                                  |
|      | 정보통신망법 시행령 제49조 제1항 | <ul style="list-style-type: none"> <li>- 의무대상 기준               <ol style="list-style-type: none"> <li>1. 상급종합병원 및 매출액 1,500억 이상인 학교</li> <li>2. 정보통신서비스 부문 매출액 100억 이상인 자</li> <li>3. 전년도 일일평균 이용자 수 100만 명 이상인 자</li> </ol> </li> </ul> |
|      | 정보통신망법 제47조 제6항     | <ul style="list-style-type: none"> <li>- 인증의 유효기간</li> <li>- 인증의 유효기간은 3년으로 하며, 유효기간이 끝나기 전에 재인증을 받아야 함.</li> </ul>                                                                                                                      |
|      | 정보통신망법 제47조 제7항     | <ul style="list-style-type: none"> <li>- 사후관리(심사)</li> <li>- 인증을 받은 자는 매년 1회 이상 사후 심사를 받아 관리체계가 지속적으로 유지되는지 확인받아야 함.</li> </ul>                                                                                                          |
|      | 정보통신망법 제76조 제1항 제3호 | <ul style="list-style-type: none"> <li>- 미취득 과태료</li> <li>- 인증 의무 대상자가 인증을 받지 아니한 경우, 3천만 원 이하의 과태료를 부과함.</li> </ul>                                                                                                                     |

- ISMS(정보보호 관리체계)의 법적 근거는 「정보통신망 이용촉진 및 정보보호 등에 관한 법률(약칭: 정보통신망법)」에 명확히 규정됨

## II. ISMS의 관리과정 설명

### 가. ISMS의 관리 과정



- ISMS 관리 과정은 5단계로 14개 통제 사항으로 구성이 됨

### 나. ISMS 관리 과정 상세 설명

| 구분        | 내용                                                                  | 산출물                               |
|-----------|---------------------------------------------------------------------|-----------------------------------|
| 정보보호 정책수립 | - 조직 전반에 걸쳐 상위 수준의 정보 보호 정책을 수립<br>- 정보 보호 수행하기 위한 조직내 각 부분의 책임을 설정 | 정보보호 정책서                          |
| 관리체계 범위설정 | - 범위를 설정하고 범위 내의 정보자산을 식별                                           | 정보보호관리체계 인증범위서                    |
| 위험관리      | - 조직문화와 정보자산에 적절한 위험관리 전략과 계획을 수립<br>- 위험을 분석하고 평가하여 위험의 우선 순위 결정   | 위험분석/평가 보고서, 정보보호 대책명세서, 정보보호 계획서 |
| 구현        | - 위험관리 단계에서 수립된 정보보호 계획에 따라 정보보호 대책을 구현하고 교육과 훈련 진행                 | 주요정보통신설비의 자산목록                    |
| 사후관리      | - 상시적인 모니터링을 수행하고 내부감사를 통해 정책 준수 상황을 확인                             | 정보보호관리체계, 내부감사보고서                 |

- IS

## III. ISMS-P 간편인증 제도 설명

## 가. ISMS-P 간편인증 제도 개념 및 법적 근거

|      |                                                                                                                        |                            |
|------|------------------------------------------------------------------------------------------------------------------------|----------------------------|
| 개념   | - 영세, 중소기업의 ISMS-P 인증 편입을 촉진하고, <b>경량화된 인증기준</b> , 보다 <b>저렴한 인증수수료</b> , <b>단축된 인증 기간</b> 등 기업 부담을 완화한 간이 ISMS-P 인증 제도 |                            |
| 법적근거 | 정보통신망법 제47조의7                                                                                                          | - 정보보호 관리체계 인증의 특례         |
|      | 정보통신망법 시행령 제49조의2                                                                                                      | - 정보보호 관리체계 인증의 특례 대상자의 범위 |

- 기존 인증 수수료 대비 ISMS 50%, ISMS-P 40% 감면, 인증 소요 기간 180일 미만 효과

## 나. ISMS-P 간편인증 제도의 대상

| 구분  | 대상                         | 세부 대상                                                         |
|-----|----------------------------|---------------------------------------------------------------|
| 소기업 | - 중소기업기본법 제2조2항에 따른 소기업    | - 대통령령으로 정하는 소기업 기준<br>- 기업이 영위하는 주된 업종별 평균매출액 기준             |
| 중기업 | - 정보통신서비스 부문 매출액이 300억원 미만 | - 중소기업기본법 제2조2항에 따른 중기업 기준<br>- 주요 정보통신설비를 직접 설치, 운영하는 기업도 해당 |
|     | - 정보통신서비스 부문 매출액이 300억원 이상 | - 주요 정보통신설비를 보유하지 않은 기업<br>- 주요 정보통신설비를 직접 설치, 운영하지 않은 기업     |

- 단, ISP, IDC, 상급 종합 병원, 대학교, 금융회사, 가상자산사업자는 ISMS-P 간편인증

## 다. ISMS-P 간편인증 제도 기준

| 대상                        | ISMS 간편인증 항목                              | ISMS-P 간편인증 항목                                                 |
|---------------------------|-------------------------------------------|----------------------------------------------------------------|
| 소기업, 정보통신매출액 300억원 미만 중기업 | 가. 관리체계 수립 및 운영(7개)<br>나. 보호대책 요구사항(33개)  | 가. 관리체계 수립 및 운영(8개)<br>나. 보호대책 요구사항(33개)<br>다. 개인정보 요구사항(21개)  |
| 주요 정보통신시설 미보유 중기업         | 가. 관리체계 수립 및 운영(11개)<br>나. 보호대책 요구사항(33개) | 가. 관리체계 수립 및 운영(11개)<br>나. 보호대책 요구사항(33개)<br>다. 개인정보 요구사항(21개) |

- 관리체계 수립 및 운영, 보호대책 요구사항 50% 수준 완화, 개인정보 요구사항 기준 유지

## IV. ISMS-P 인증 제도 강화방안

## 가. 인증제도 구조 측면 개선방안

| 구분        | 개선방안               | 세부 개선방안                                                               |
|-----------|--------------------|-----------------------------------------------------------------------|
| 제도 및 거버넌스 | - 주요 인프라 기업 인증 의무화 | - 기존 자율이었던 ISMS-P를 <b>주요 공공시스템, 통신사, 대규모 플랫폼</b> 등에 의무화하여 상시적 관리체계 구축 |
|           | - 법제도 정비           | - 「개인정보 보호법」 및 「정보통신망법」 개정을 추진하고, 대규모 기업에는 강화된 별도 인증 기준을 적용           |



|              |                          |                                                                             |
|--------------|--------------------------|-----------------------------------------------------------------------------|
|              | - 대국민 파급력 고려<br>차등 기준 적용 | - 통신사, 대규모 플랫폼 등 국민 생활에 파급력 큰 기업에<br>대해서는 일반 기업보다 <b>강화된 인증기준</b> 을 마련하여 적용 |
| 사후관리<br>및 제재 | - 인증 취소                  | - 사후심사 과정에서 인증 기준 미달하는 <b>중대 결함</b> 발견 시,<br>위원회 의결을 거쳐 인증 취소하는 강력 제재 도입    |
|              | - 적시 특별 심사 제도화           | - 유출 사고 발생 시 <b>적시</b> 에 특별 사후심사를 착수하여 인증<br>유지 적합성을 원점 재검토                 |

#### 나. 인증제도 수행 측면 개선방안

| 구분             | 개선방안                  | 세부 개선방안                                                                            |
|----------------|-----------------------|------------------------------------------------------------------------------------|
| 심사 방법<br>혁신    | - 핵심항목 선(先)검증         | - 예비심사 단계에서 핵심 항목을 미리 검증하고, 미충족 시<br><b>본심사 진입 불가(신청 반려)</b> 조치로 심사 효율성 확보         |
|                | - 현장 실증형 심사 전환        | - 기존 서면·샘플링 위주 점검을 지양하고, <b>Core 시스템 중심의<br/>현장 실증형 심사</b> 로 전환, 문서와 실제 운영 간 괴리 제거 |
| 기술 검증<br>강화    | - 기술심사 도입             | - 고위험 및 사고 기업 대상 취약점 진단 및 <b>모의침투</b> 방식<br>심사를 적용하여 해킹 방어력 실전 검증                  |
|                | - 인증범위 자산현황 제출<br>의무화 | - 인증 신청 시 '관리체계 운영명세서' 외에 ' <b>자산현황</b> ' 제출을<br>추가하여, 관리 사각지대 식별                  |
| 인적 역량<br>및 리소스 | - 심사 리소스 대폭 확충        | - 사고 기업 심사 시 인력·기간을 <b>2배 확대</b> 하여 집중 점검<br>- 결함 발생 수준에 따라 심사 인력을 유연하게 추가 투입      |
|                | - 전문성 및 교육 강화         | - 심사원 대상 <b>AI 등 신기술 교육</b> 을 통해 전문성 제고<br>- 분야별 인증위원회 운영으로 심의의 전문성 확보             |

- ISMS-P 인증 제도 개선을 통한 **기술 실증형 상시 보안**으로의 패러다임 전환은 **국민 신뢰 기반의 디지털  
안심 국가**를 구현하는 핵심 동력 기대.

“끝”



## ITPE 기술사회

### 제138회 정보처리기술사 기출문제 해설집

|     |                                                                                                                                                                                                                                  |
|-----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 대 상 | 정보관리기술사, 컴퓨터시스템응용기술사, 정보통신기술사, 정보시스템감리사 시험                                                                                                                                                                                       |
| 발행일 | 2026년 02월 07일                                                                                                                                                                                                                    |
| 집 필 | 강정배PE, 정상PE, 전일PE, 백현PE, 강진우PE                                                                                                                                                                                                   |
| 출 판 | <b>ITPE(Information Technology Professional Engineer)</b>                                                                                                                                                                        |
| 주 소 | ITPE 대치점 서울시 강남구 선릉로 86길 17 선릉엠티빌딩 7층<br>ITPE 선릉점 서울시 강남구 선릉로 86길 15, 3층 IT교육센터 아이티피이<br>ITPE 강남점 서울시 강남구 테헤란로 52길 21 파라다이스벤처타워 3층 303호<br>ITPE 영등포점 서울시 영등포구 당산동2가 하나비즈타워 7층 ITPE<br>ITPE 을지로점 서울시 중구 삼일대로 363, 2615호(장교동 장교빌딩) |
| 연락처 | 070-4077-1267 / <a href="mailto:itpe@itpe.co.kr">itpe@itpe.co.kr</a>                                                                                                                                                             |

본 저작물은 [ITPE\(아이티피이\)](http://itpe.co.kr)에 저작권이 있습니다.

저작권자의 허락없이 **본 저작물을 불법적인 복제 및 유통, 배포**하는 경우  
**법적인 처벌**을 받을 수 있습니다.